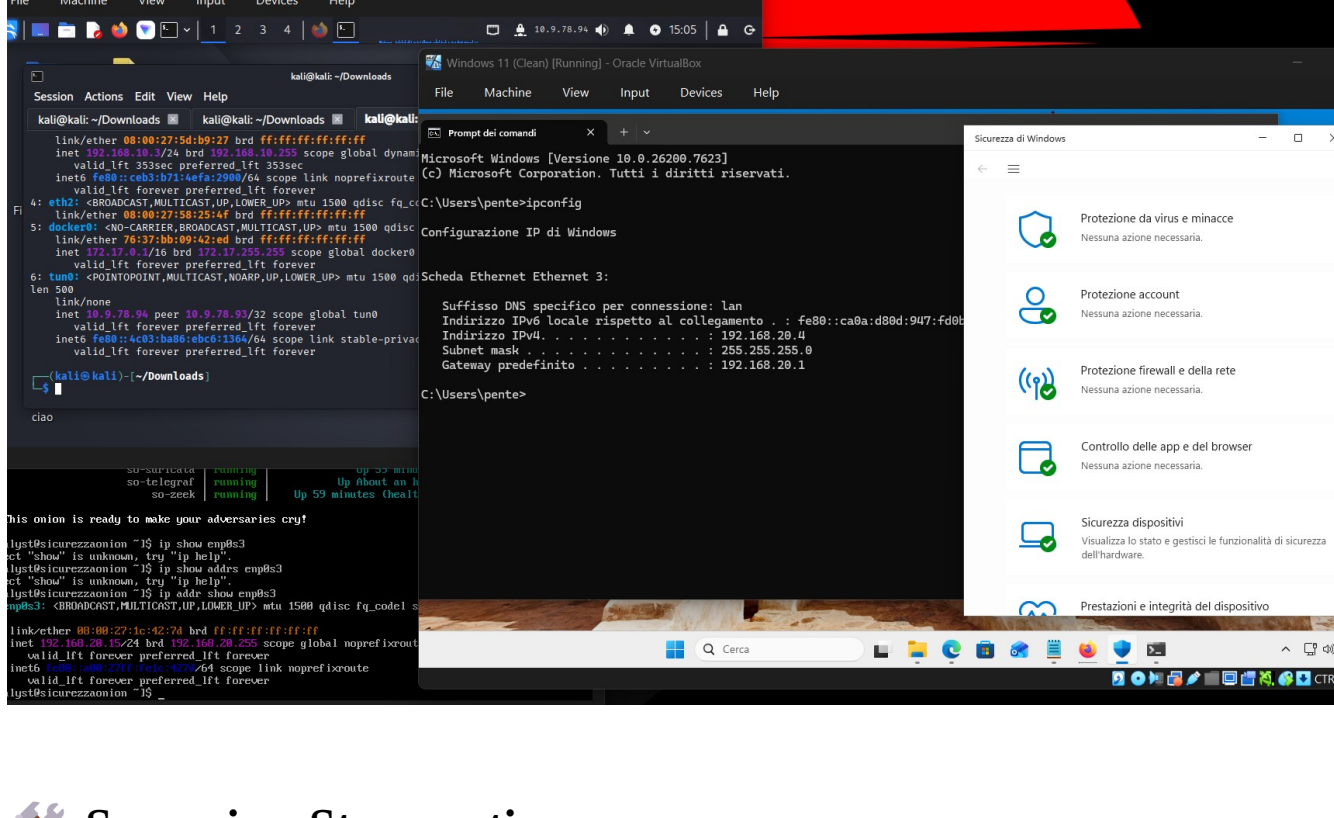


DNS Spoofing

Panoramica del Progetto

Questo laboratorio documenta un settore d'attacco avanzato che sfrutta la manipolazione del SecureStore di Windows 11 e l'iniezione di configurazioni proxy per intercettare, decifrare e sottrarre dati sensibili (credenziali e cookie di sessione) da una vittima ignara.



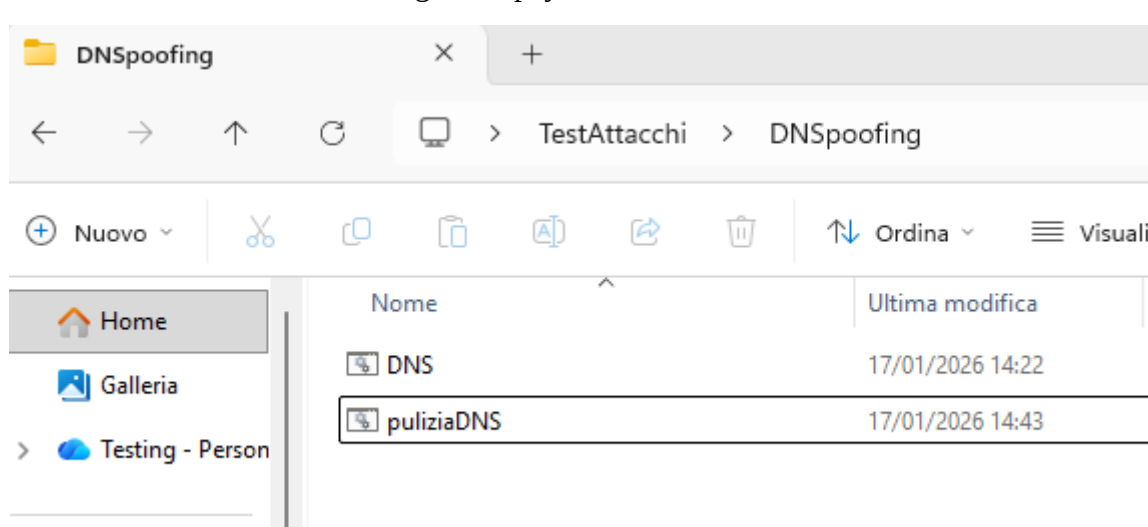
- **Attaccante:** Kali Linux con fran

- **Altro:** File Scripting, Tunnel(per simulare attacco da rete esterna)
-

Fasi dell'Attacco

1. Infiltrazione e Manipolazione del Sistema

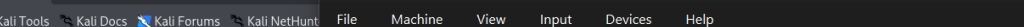
L'attacco inizia con l'esecuzione dello script DNS. Grazie all'affidabilità di piattaforme tipo Github, l'utente viene indotto a scaricare ed eseguire il payload

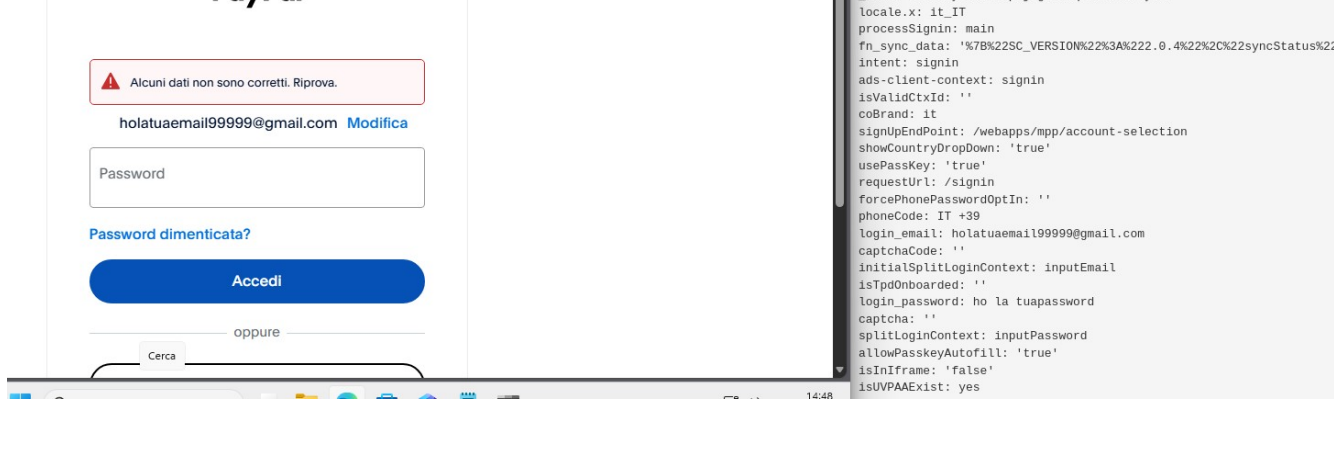
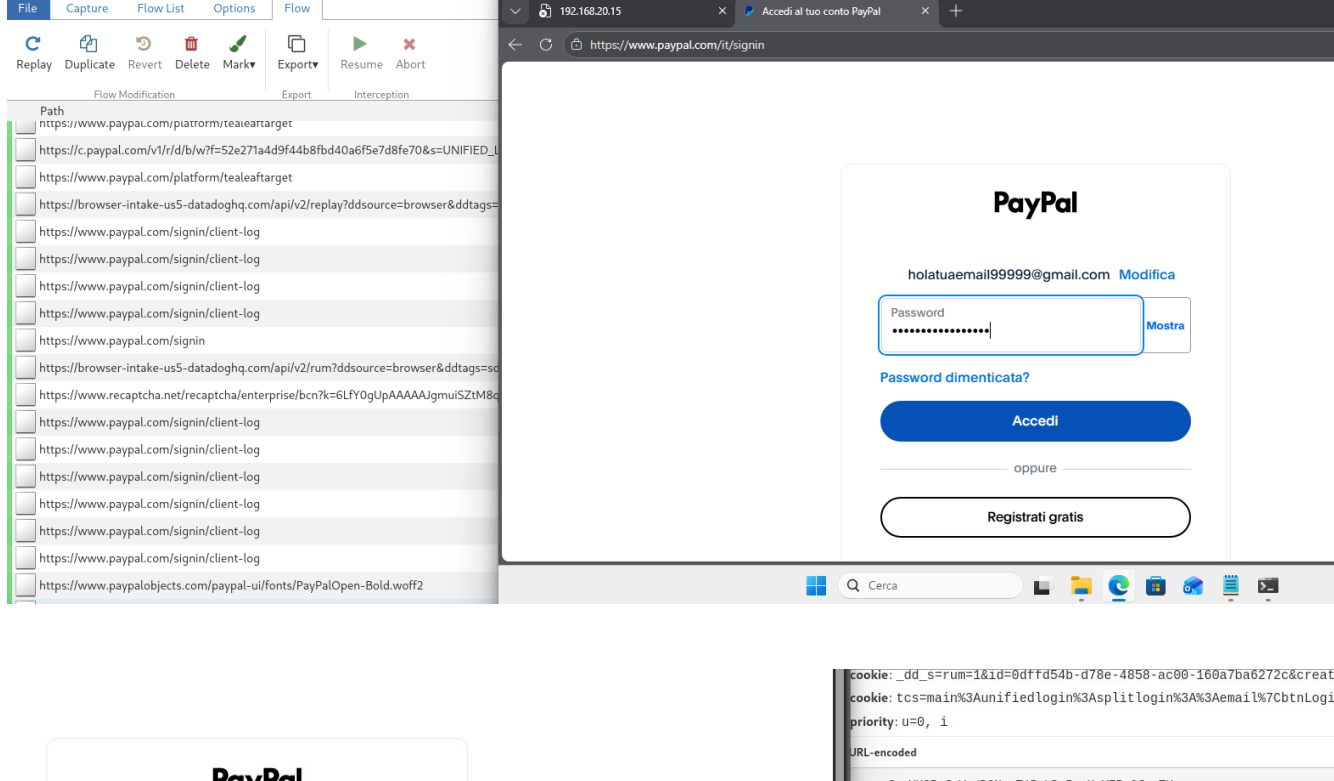


- **Installazione CA Falsa:** Lo script DNS scarica un certificato Root non autorizzato e lo installa forzatamente nel magazzino dei certificati affidabili di Windows.
- **Proxy Setup:** Vengono modificate le chiavi di registro per reindirizzare tutto il traffico web (porte 80/443) verso l'indirizzo dell'attaccante.
- **Ripristino:** Lo script puliziaDNS ripristina la macchina dall'attacco

Con il certificato malevolo installato, i bro

- **Cattura Credenziali:** Durante il login su piattaforme come **PayPal**, l'email

- (holatuaemail99999@gmail.com) e la password vengono catturate in chiaro nella dashboard di mitmproxy.
- **Analisi dei Flussi:** L'attaccante ha visibilità completa su tutti i percorsi (path) e le chiamate API effettuate dal browser della vittima.
- 



3. Furto dei Cookie e Bypass MFA

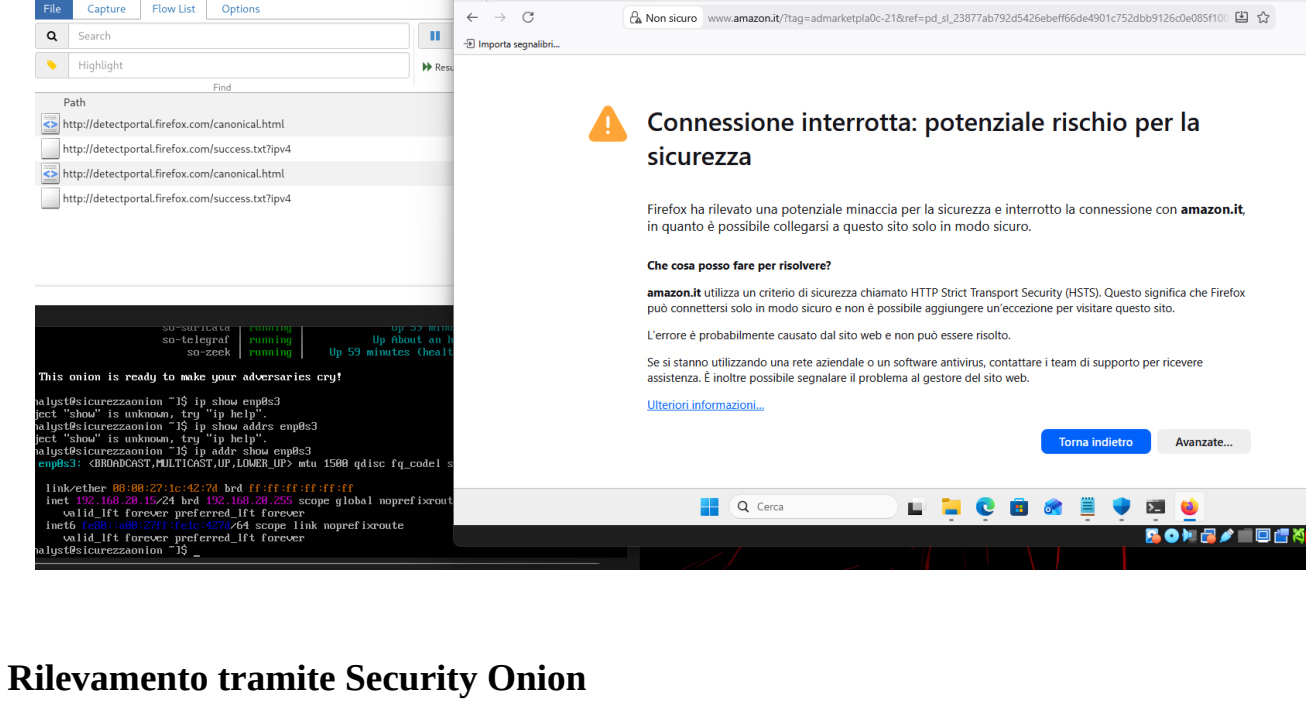
L'aspetto più critico è il furto del **COOKIE** di sessione.

- **Oltre la Password:** Catturando i cookie dopo un login andato a buon fine, l'attaccante può clonare la sessione attiva.
- **Bypass 2FA:** Poiché il cookie viene generato *dopo* che l'utente ha inserito il codice di sicurezza (MFA), l'attaccante che utilizza quel cookie risulta già autenticato per il server, rendendo inutile la protezione a due fattori.

🔵 **Analisi della Difesa (Blue Team)**

Differenze tra Browser

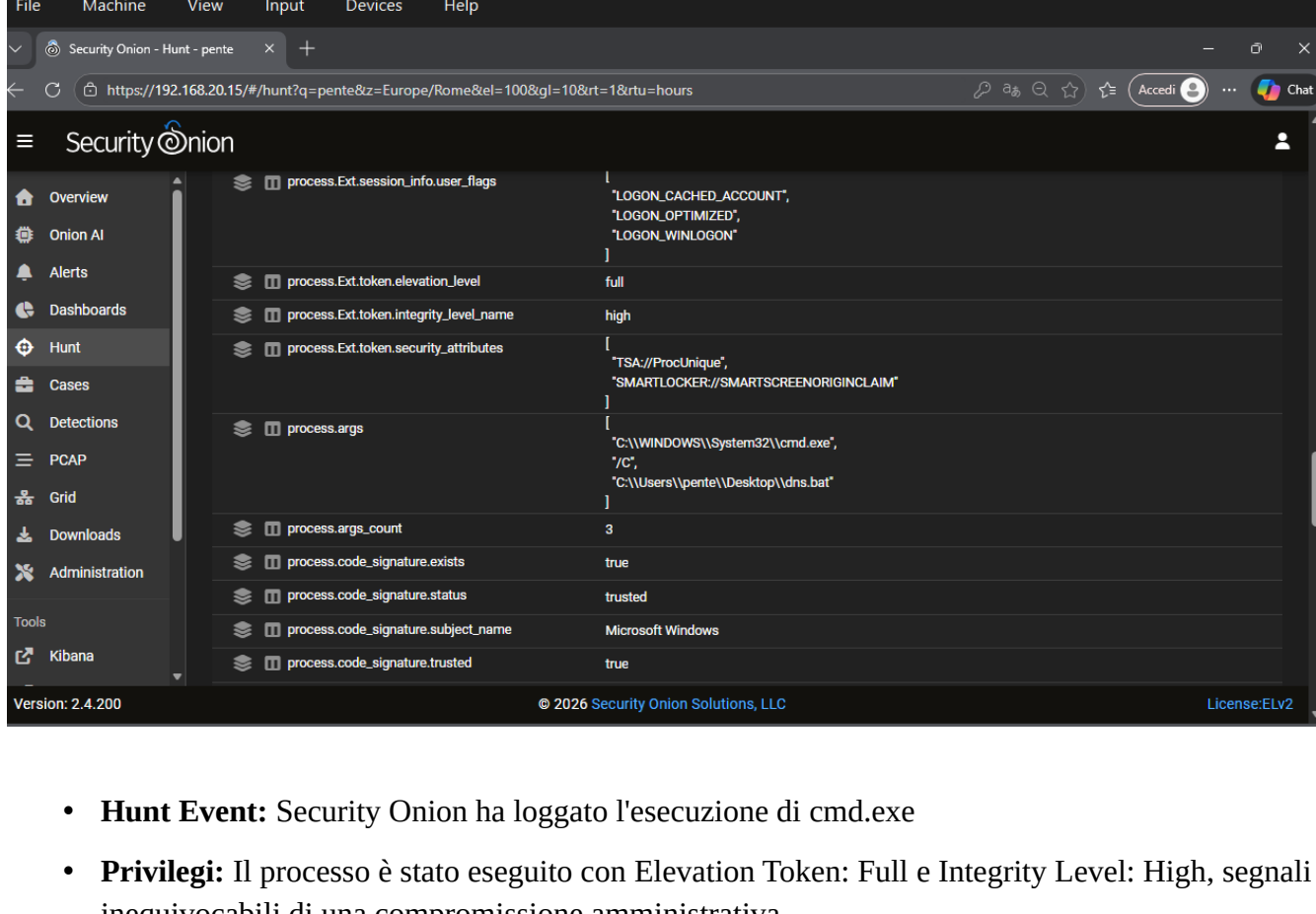
- **Mozilla Firefox:** Ha bloccato l'attacco. Firefox utilizza un proprio database di certificati interno e ha rilevato la firma non valida, emettendo un avviso di "Connessione interrotta: potenziale rischio".



The screenshot shows the Kali Linux desktop environment with the OpenSearch Dashboards interface. The top navigation bar includes links for OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, and Kali NetHunt. The main interface displays a 'Flow List' tab with a table of network flows. The first flow is highlighted, showing details for IP 192.168.20.15.



Windows 11 (Clean) [Running] - Oracle VirtualBox



- inequívocamente a uma compreensão administrativa.

vulnerabilità critico. Un v

Rischi rilevati:

1. Account Takeover totale tramite Session Hijacking.

2. Incapacity

3. Necessità di monitoraggio costante dei registri di sistema e dell'installazione di nuovi certificati Root.

⚠ **Nota sulla fattibilità reale:** Sebbene in questo scenario di test i file utilizzati possano risultare identificabili, è cruciale comprendere che in un attacco reale la pericolosità aumenterebbe esponenzialmente. Un attaccante esperto, utilizzando tecniche avanzate di Ingegneria Sociale, potrebbe camuffare il file batch (es. convertendolo in un eseguibile con icone legittime, firmandolo digitalmente o nascondendolo in un software "crackato"). In tali condizioni, senza strumenti di analisi comportamentale o un occhio estremamente esperto, l'attacco risulterebbe estremamente difficile da